Progetto S9_L5:

Threat Intelligence e IOC

Introduzione e Contesto Operativo

Il report presenta i risultati di un' analisi tecnica di Threat Intelligence e Indicatori di Compromissione (IOC). Nella Threat Intelligence, l'analisi del traffico di rete trascende il semplice monitoraggio, costituendo una funzione strategica vitale per la decodifica delle Tattiche, Tecniche e Procedure (TTP) degli avversari.

Il report si concentra sull'analisi del file di cattura di rete Cattura_U3_W1_L3.pcapng al fine di rilevare eventuali attività malevoli all'interno di un ambiente di rete controllato. L'obiettivo è ricostruire la visibilità del traffico per definire una strategia di sicurezza e stabilire obiettivi difensivi supportati da dati concreti.

Introduzione Teorica e Obiettivi dell'Analisi

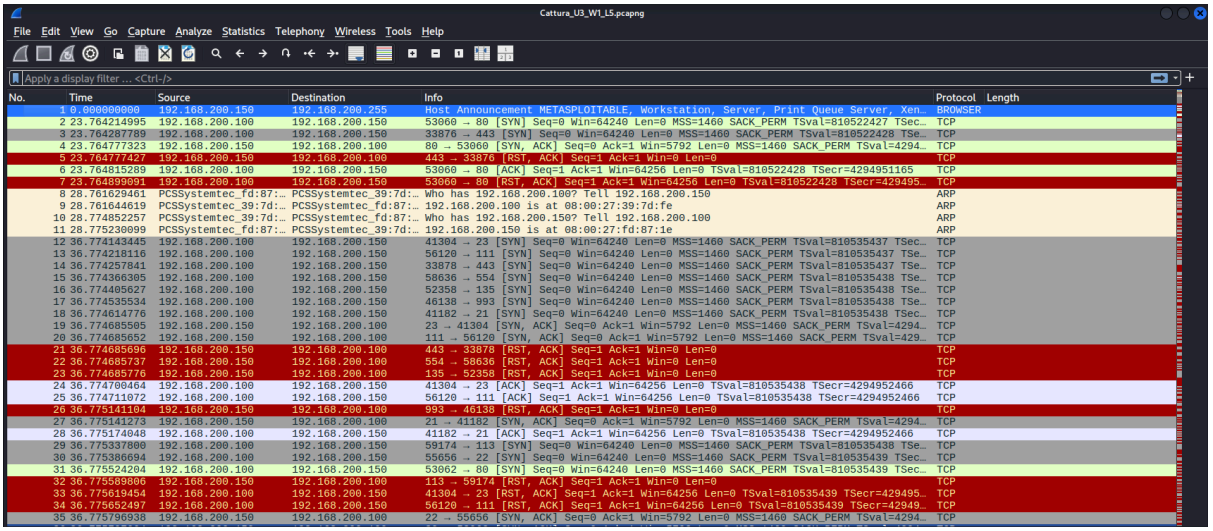
La Threat Intelligence è la disciplina dedicata alla raccolta e all'analisi di informazioni riguardanti potenziali minacce, fornendo ai decisori aziendali il contesto necessario per mitigare i rischi informatici. In questo quadro, gli Indicatori di Compromissione (IOC) , come indirizzi IP malevoli, hash di file o pattern di traffico, segnalano un attacco in corso o pregresso.

Gli obiettivi primari di questa attività includono:

1. **Identificazione degli IOC**: Rilevazione di marker tecnici basati sul traffico TCP/IP.
2. **Formulazione di ipotesi sui vettori di attacco:** Ricostruzione delle metodologie di intrusione e ricognizione.
3. **Definizione di strategie di mitigazione:** Sviluppo di contromisure a breve termine e piani di hardening a lungo termine.

Analisi del Traffico e Identificazione degli IOC

Per preservare l'integrità dei dati e prevenire contaminazioni , l'analisi è stata eseguita in un ambiente isolato sulla macchina virtuale Kali Linux. Questo approccio garantisce che le operazioni avvengano separatamente dall'ambiente di produzione host, rispettando gli standard di sicurezza operativa. L'analisi dei flussi rivela un'interazione anomala e sistematica tra due endpoint. La natura sequenziale e l'elevata frequenza delle connessioni indicano chiaramente un'attività automatizzata di esplorazione della superficie d'attacco.



Analisi

Gli IOC rappresentano le "impronte digitali" lasciate da un attaccante malevolo. La loro analisi è essenziale per validare l'ipotesi di una compromissione in corso.

Dall'ispezione della cattura di rete sono stati estratti i seguenti parametri chiave:

- IP Sorgente: 192.168.200.150
- IP Destinazione (Vittima): 192.168.200.100
- Protocolli Rilevati: TCP, BROWSER, ARP.

Un dato fondamentale emerge dai pacchetti ARP. Questo traffico indica che l'attaccante e la vittima risiedono nello stesso segmento di rete locale. Tale evidenza suggerisce che l'attaccante abbia già ottenuto l'accesso alla rete interna o stia operando da una postazione fisicamente collegata alla stessa VLAN.

Valutazione del Traffico TCP

È stata osservata una sequenza massiva e aggressiva di pacchetti con flag [SYN] diretti verso una vasta gamma di porte sulla vittima, incluse 21 (**FTP**), 22 (**SSH**), 23 (**Telnet**), 25 (**SMTP**), 53 (**DNS**), 80 (**HTTP**), 110 (**POP3**), 111 (**RPC**), 139 (**NetBIOS**), 443 (**HTTPS**) e 445 (**SMB**). La ricezione sistematica di pacchetti [RST, ACK] dalla vittima conferma che il target sta rifiutando le connessioni su porte chiuse, configurando uno scenario di port scanning.

Host Announcement

L'indicatore più critico è rappresentato dal pacchetto 1 (protocollo BROWSER), una Host Announcement in cui il target si identifica esplicitamente come "**METASPLOITABLE**". Si tratta di un segnale di estrema rilevanza: il sistema è "rumoroso" e trasmette la propria identità via NetBIOS/SMB, dichiarando di essere una macchina deliberatamente vulnerabile.

1	0.000000000	192.168.200.150	192.168.200.255	Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xen…	BROWSER
2	23.764214995	192.168.200.100	192.168.200.150	53060 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522427 TSec…	TCP
3	23.764287789	192.168.200.100	192.168.200.150	33876 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522428 TSe…	TCP
4	23.764777323	192.168.200.150	192.168.200.100	80 → 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294…	TCP
5	23.764777427	192.168.200.150	192.168.200.100	443 → 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	TCP
6	23.764815289	192.168.200.100	192.168.200.150	53060 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165	TCP
7	23.764899091	192.168.200.100	192.168.200.150	53060 → 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=429495…	TCP

Queste evidenze ci permettono di formulare un'ipotesi importante riguardo l'attività rilevata.

Un **IOC** di criticità estrema è la stringa "**METASPLOITABLE**" rilevata nel protocollo BROWSER. La presenza di un'istanza "insecure by design" in un segmento di rete accessibile rappresenta di per sé una vulnerabilità critica, poiché tali sistemi sono progettati specificamente per essere sfruttati tramite exploit noti.

Valutazione del Traffico TCP

Le catture mostrano inoltre un volume importante di pacchetti evidenziati in rosso, corrispondenti a flag [RST, ACK] inviati dal target (192.168.200.100) verso la sorgente. Questa evidenza tecnica indica un TCP Connect Scan (o SYN Scan) su porte chiuse. Il numero elevato di questi pacchetti suggerisce l'uso di uno script automatizzato e aggressivo, non compatibile con un'attività manuale, volto a mappare rapidamente i servizi attivi. Si conferma l'utilizzo di uno strumento automatizzato di scansione, probabilmente Nmap.

74	36.777430632	192.168.200.150	192.168.200.100	707 → 56990 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	TCP
75	36.777430741	192.168.200.150	192.168.200.100	436 → 35638 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	TCP
76	36.777473018	192.168.200.100	192.168.200.150	36138 → 580 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSe…	TCP
77	36.777522494	192.168.200.100	192.168.200.150	52428 → 962 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSe…	TCP
78	36.777623082	192.168.200.150	192.168.200.100	98 → 34120 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	TCP
79	36.777623149	192.168.200.150	192.168.200.100	78 → 49780 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	TCP
80	36.777645027	192.168.200.100	192.168.200.150	41874 → 764 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSe…	TCP
81	36.777680898	192.168.200.100	192.168.200.150	51506 → 435 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535441 TSe…	TCP
82	36.777758636	192.168.200.150	192.168.200.100	580 → 36138 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	TCP
83	36.777758696	192.168.200.150	192.168.200.100	962 → 52428 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	TCP
84	36.777871245	192.168.200.150	192.168.200.100	764 → 41874 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	TCP
85	36.777871293	192.168.200.150	192.168.200.100	435 → 51506 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	TCP
86	36.777893298	192.168.200.100	192.168.200.150	33042 → 445 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=42949…	TCP
87	36.777912717	192.168.200.100	192.168.200.150	46990 → 139 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=42949…	TCP
88	36.777986759	192.168.200.100	192.168.200.150	60632 → 25 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=429495…	TCP
89	36.778031265	192.168.200.100	192.168.200.150	37282 → 53 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=429495…	TCP

Valutazione dei Vettori di Attacco

Le ipotesi principali sono:

1. **Ricognizione Attiva tramite Tool Automatizzati:** L'attaccante sta impiegando strumenti come Nmap per mappare sistematicamente porte critiche (21, 22, 23, 25, 53, 80, 111, 443, 445). L'aggressività della scansione suggerisce un tentativo di identificare rapidamente vettori di ingresso.
2. **Sfruttamento di Servizi Obsoleti e Misconfiguration:** Il target identificato come Metasploitable suggerisce che l'attaccante sta attivamente cercando servizi noti per le loro vulnerabilità (come FTP o Telnet) al fine di sfruttarli con exploit pubblici e affidabili.

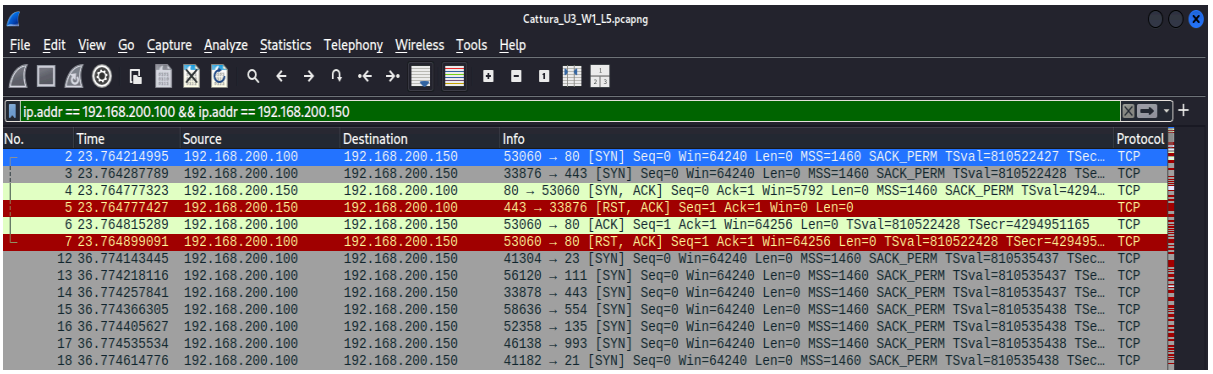
L'impatto potenziale, se l'attività non venisse interrotta, includerebbe l'ottenimento di una shell remota e il successivo movimento laterale all'interno della rete.

Filtri Wireshark Strategici

Per approfondire l'analisi, si è scelto di utilizzare i seguenti filtri:

Primo filtro:

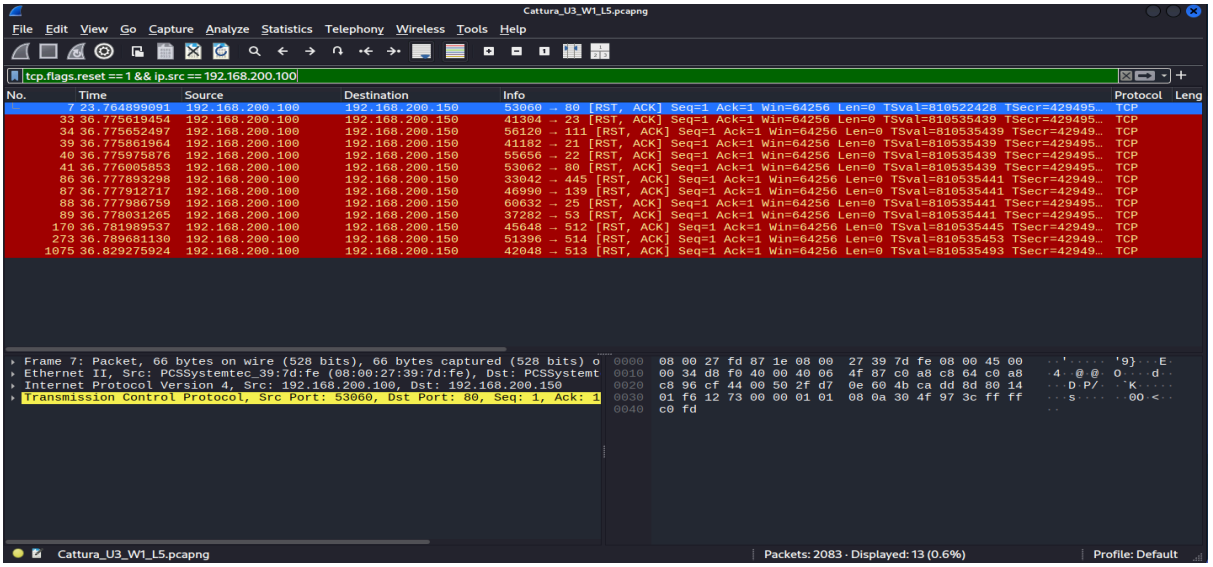
ip.addr == 192.168.200.100 && ip.addr == 192.168.200.150



Spiegazione: con questo filtro si isola il flusso di traffico specifico tra l'attaccante e il target per un'analisi che non presenti rumore ambientale.

Secondo filtro:

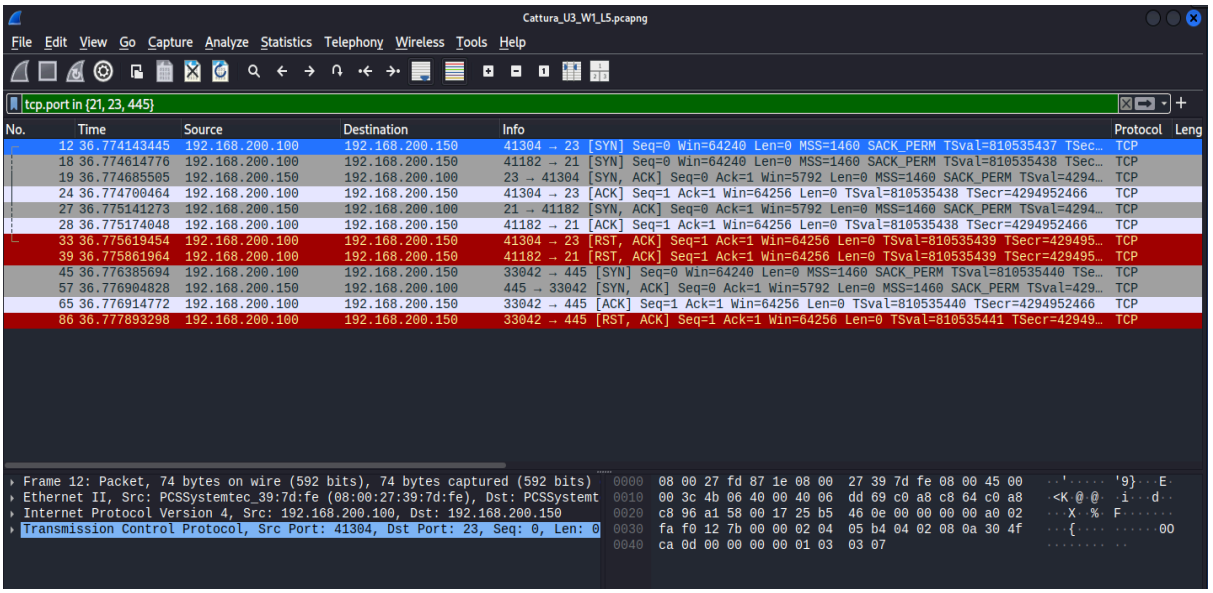
tcp.flags.reset == 1 && ip.src == 192.168.200.100



Filtro di Noise Reduction: Visualizza esclusivamente i rifiuti di connessione del target, permettendo di mappare con precisione l'estensione della scansione subita.

Terzo filtro:

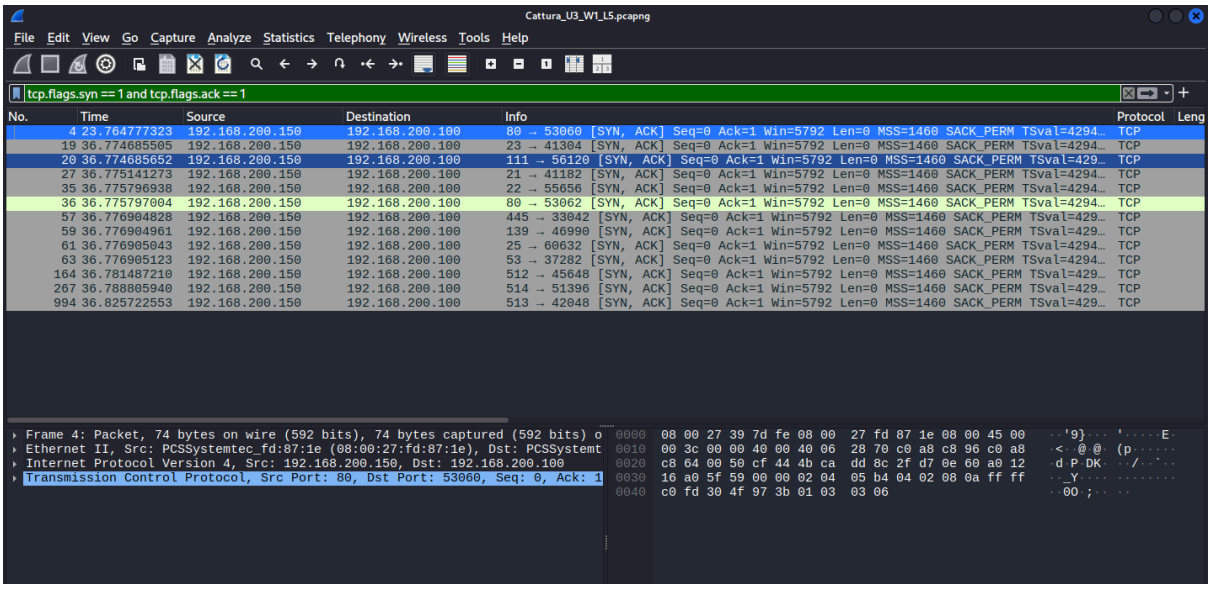
tcp.port in {21, 23, 445}



Spiegazione: isola i tentativi di connessione verso servizi ad alto rischio (**FTP, Telnet, SMB**) per verificare eventuali tentativi di autenticazione o exploit.

Quarto filtro:

tcp.flags.syn == 1 and tcp.flags.ack == 1



Spiegazione: Il filtro isola le risposte positive del server. In un contesto di centinaia di tentativi falliti, ha immediatamente messo in luce l'accettazione della connessione da parte della porta **445**, configurandosi come l'unico vero "successo" per l'aggressore.

Strategie di Mitigazione e Risposta agli Incidenti

È di fondamentale importanza adottare una difesa stratificata per neutralizzare l'attività di scansione e prevenire escalation future.

Azioni Immediate (Riduzione Impatto):

- **Interdizione IP**: Implementazione di una regola "Deny" sul Firewall perimetrale per l'IP 192.168.200.150.
- **Terminazione Servizi Esposti**: Chiusura immediata delle porte non essenziali sul target, con priorità su Telnet (23) e FTP (21).

Azioni Preventive e Strategiche:

- **Segmentazione di Rete:** Isolare le macchine vulnerabili (come Metasploitable) in una VLAN a parte. Tali sistemi non devono essere raggiungibili dal resto della rete produttiva.
- **Sistemi IDS/IPS**: Configurare firme specifiche per il rilevamento di pattern di port scanning (es. soglie di pacchetti SYN/RST per secondo).
- **Hardening e Monitoraggio:** La chiusura delle porte è una misura temporanea; è necessario un hardening strutturale del sistema e un monitoraggio continuo dei log, poiché un attaccante persistente potrebbe variare l'IP sorgente.

Conclusioni

L'analisi tecnica ha confermato un'attività di ricognizione ostile, caratterizzata da un alto grado di automazione. La correlazione tra gli Indicatori di Compromissione (IOC) basati sui flag TCP e l'identificazione di un target "Metasploitable" segnala un rischio elevato e imminente di compromissione del sistema.

È fondamentale concepire la Threat Intelligence non come un processo statico, ma come un ciclo continuo e dinamico di monitoraggio e risposta. In scenari di minaccia complessi, l'unico approccio per assicurare un'effettiva resilienza consiste nell'anticipare le mosse degli avversari attraverso un'analisi approfondita dei dati di rete.